Halokazi API

Reference for the endpoints implemented so far: authentication (registration, phone verification by OTP, login, logout, current user), the public site data behind the landing page (jobs, filters, top employers, live stats, CV templates) and the job seeker's own settings. Version 0.4, 29 October 2026.

New in 0.4: password reset by SMS code (`POST /api/auth/password/forgot`, `/password/reset`, section 2) and saved jobs (`/api/me/saved-jobs`, section 4). The backend now listens on port 8081 by default.
0.3 added the job seeker Settings endpoints in section 4 (`/api/me/settings` for account details, notifications, privacy and language, and `POST /api/me/password`), with the error codes `JOB_SEEKERS_ONLY` and `CURRENT_PASSWORD_INCORRECT`. They need database migration `db/oracle/05_settings.sql`.
0.2 added the public site endpoints in section 3 (`/api/public/...`), `JOB_NOT_FOUND`, and a 400 instead of a 500 for wrongly typed query or path parameters.

1. Conventions

Topic	Rule
Base path	Authentication is under `/api/auth`; public site data is under `/api/public`. Locally the server is `http://localhost:8081` (set by `server.port`; the Vite dev proxy points there).
Public endpoints	Everything under `/api/public` is read-only and needs no token. A token, if sent, is ignored.
Bilingual lists	Managed list values (regions, job types, categories, education levels) are objects `{ "code", "nameEn", "nameSw" }`. Filter and store the `code`; show the name in the user's language.
Format	Requests and responses are JSON. Send `Content-Type: application/json`; any other body type gets `415 UNSUPPORTED_MEDIA_TYPE`.
Authentication	Login and OTP verification return a **token**. Protected endpoints need the header `Authorization: Bearer <token>`.
Sessions	A token stops working after 10 minutes without a request (each request resets the clock), 12 hours after it was issued, or at logout.
Phone numbers	Tanzanian mobile numbers starting with 6 or 7. Accepted as `712345678`, `712 345 678`, `0712345678`, `255712345678` or `+255712345678`. Responses always use `+255712345678`.
Emails	Compared without regard to capitalisation; stored in lowercase.
Timestamps	ISO-8601 in UTC, e.g. `2026-10-28T21:11:48.688Z`.
Enum values	Upper case in responses (`JOB_SEEKER`, `ACTIVE`). The `role` field in registration also accepts lower case.
CORS	Browsers may call the API from `http://localhost:5173` (the Vite dev server).

Error format

Every error, from every endpoint, has the same shape. Fields that are empty are left out.

```
{
  "code": "VALIDATION_FAILED",              // stable code: switch on this
  "message": "One or more fields are invalid.",
  "fieldErrors": [                         // only for field problems
    { "field": "phone",
      "message": "Enter a valid Tanzanian mobile number, e.g. 7XX XXX XXX." }
  ],
  "retryAfterSeconds": 30,                 // only for rate limits and lockouts
  "details": { "phone": "+255712345678" }   // extra data for some codes
}
```

When `retryAfterSeconds` is present, the same value is also sent in the `Retry-After` HTTP header.

The account lifecycle

```
register  -->  account PENDING_VERIFICATION, OTP sent by SMS
otp/verify -->  account ACTIVE, phone verified, user is logged in (token returned)
login      -->  only works for ACTIVE accounts; no OTP at login
```

2. Authentication endpoints

Method	Path	Auth	Purpose
POST	`/api/auth/register`	none	Create an account and send an OTP
POST	`/api/auth/otp/verify`	none	Verify the phone with the OTP; logs the user in
POST	`/api/auth/otp/resend`	none	Send a new OTP
POST	`/api/auth/login`	none	Log in with phone or email and password
GET	`/api/auth/me`	Bearer	The logged-in user
POST	`/api/auth/logout`	Bearer	End the current session
POST	`/api/auth/password/forgot`	none	Send a password-reset code by SMS
POST	`/api/auth/password/reset`	none	Set a new password with that code

`POST /api/auth/register` — No auth

Creates a **job seeker** or **employer** account in state `PENDING_VERIFICATION` and sends a 6-digit OTP by SMS to the phone. A job seeker also gets an empty profile; an employer gets an employer record with verification status `NOT_SUBMITTED`.

Field	Type	Required	Rules
`role`	string	yes	`job_seeker` or `employer` (any capitalisation)
`fullName`	string	yes	Max 150 characters. For an employer this is the company name.
`phone`	string	yes	Tanzanian mobile number (see Conventions). Must not be registered already.
`email`	string	yes	Valid email, max 254 characters. Required for both roles. Must not be registered already.
`password`	string	yes	8 to 64 characters, with at least one uppercase letter, one lowercase letter, one digit and one special character.

Field	Type	Required	Rules
`repeatPassword`	string	yes	Must equal `password`.

Request

```
{
  "role": "job_seeker",
  "fullName": "Asha Juma",
  "phone": "712345678",
  "email": "asha.juma@example.com",
  "password": "Str0ng!Pass",
  "repeatPassword": "Str0ng!Pass"
}
```

Response: 201 Created

```
{
  "userId": 61,
  "phone": "+255712345678",
  "role": "JOB_SEEKER",
  "otpExpiresInSeconds": 300,      // the OTP is valid for this long
  "resendAvailableInSeconds": 30   // wait this long before calling otp/resend
}
```

Errors

Status	code	When
400	VALIDATION_FAILED	A field breaks a rule; `fieldErrors` lists every problem at once
400	MALFORMED_REQUEST	The body is not valid JSON
409	PHONE_ALREADY_REGISTERED	The phone belongs to a verified account. `fieldErrors` points at `phone`.
409	PHONE_PENDING_VERIFICATION	The phone is registered but never verified. `details.phone` has the number; send the user to the OTP screen and call otp/resend.
409	EMAIL_ALREADY_REGISTERED	The email is taken. `fieldErrors` points at `email`.
502	SMS_DELIVERY_FAILED	The account was created but the SMS could not be sent. Call otp/resend.

`POST` `/api/auth/otp/verify` — No auth

Checks the OTP. On success the account becomes `ACTIVE`, the phone is marked verified, and the user is **logged in**: the response is the same as a login.

Field	Type	Required	Rules
`phone`	string	yes	The phone used at registration, any accepted format
`code`	string	yes	Exactly 6 digits

Request

```
{ "phone": "712345678", "code": "483920" }
```

Response: 200 OK (the *auth response*, also returned by login)

```
{
  "token": "v2oRmiGXNvcH5-MiIxD4s1-pICemTLXFVKS_RNR9Qbg",
  "expiresAt": "2026-10-28T21:11:48.688Z",   // absolute expiry (12 hours)
  "idleTimeoutSeconds": 600,                 // expires after 10 minutes without a request
  "user": {
    "userId": 61,
    "fullName": "Asha Juma",
    "email": "asha.juma@example.com",
    "phone": "+255712345678",
    "role": "JOB_SEEKER",                    // JOB_SEEKER | EMPLOYER
    "accountStatus": "ACTIVE",
    "preferredLanguage": "EN",               // EN | SW
    "employerVerificationStatus": null       // null for job seekers, see below
  }
}
```

`employerVerificationStatus` is `null` for job seekers. For employers it is one of `NOT_SUBMITTED` (new account), `PENDING_REVIEW`, `APPROVED` or `REJECTED`.

Errors

Status	code	When
400	VALIDATION_FAILED	Bad phone format, or the code is not 6 digits
400	OTP_INVALID	Wrong code. `details.remainingAttempts` says how many tries are left. Also returned for an unknown or already-verified phone.
400	OTP_EXPIRED	The code is older than 5 minutes, or there is no active code. Call otp/resend.
429	OTP_ATTEMPTS_EXCEEDED	5 wrong tries on this code. It no longer works, even with the right digits. Call otp/resend.

POST /api/auth/otp/resend

No auth

Sends a new OTP to a phone that is waiting for verification. The previous code stops working. For privacy the reply is identical whether or not the phone belongs to such an account, so it cannot be used to check which numbers are registered.

Field	Type	Required	Rules
phone	string	yes	Tanzanian mobile number, any accepted format

Request

```
{ "phone": "712345678" }
```

Response: 202 Accepted

```
{
  "message": "If this number has an account awaiting verification, a new code has been sent.",
  "otpExpiresInSeconds": 300,
  "resendAvailableInSeconds": 30
}
```

Errors

Status	code	When
400	VALIDATION_FAILED	Bad phone format
429	OTP_RESEND_TOO_SOON	Less than 30 seconds since the last code. `retryAfterSeconds` says how long to wait.
429	OTP_RESEND_LIMIT_REACHED	3 resends already used in the current 30-minute window. `retryAfterSeconds` says when the window ends.
502	SMS_DELIVERY_FAILED	The SMS could not be sent. This attempt does not count towards the limits.

POST /api/auth/login

No auth

Logs in with a phone number **or** an email address, plus the password. Only `ACTIVE` (verified) accounts can log in.

Field	Type	Required	Rules
`identifier`	string	yes	Phone number (any accepted format) or email address. Max 254 characters.
`password`	string	yes	Max 64 characters

Request

```
{ "identifier": "712345678", "password": "Str0ng!Pass" }
```

Response: 200 OK, the same auth response as otp/verify (token, expiresAt, idleTimeoutSeconds, user).

Errors

Status	code	When
400	VALIDATION_FAILED	A field is missing
401	INVALID_CREDENTIALS	Unknown phone/email or wrong password. Both cases give the same reply on purpose.
423	ACCOUNT_LOCKED	5 wrong passwords in a row lock the account for 15 minutes; the 5th wrong attempt already returns this. `retryAfterSeconds` says how long is left.
403	PHONE_NOT_VERIFIED	Correct password, but the phone was never verified. `details.phone` has the number; send the user to the OTP screen.
403	ACCOUNT_DISABLED	The account is suspended, deactivated or deleted.

`GET /api/auth/me` — Bearer token

Returns the logged-in user. No body. Each successful call also resets the 10-minute idle timer.

```
Authorization: Bearer v2oRmiGXNvcH5-MiIxD4s1-pICemTLXFVKS_RNR9Qbg
```

Response: 200 OK, the `user` object from the auth response:

```
{
  "userId": 61,
  "fullName": "Asha Juma",
  "email": "asha.juma@example.com",
  "phone": "+255712345678",
  "role": "JOB_SEEKER",
  "accountStatus": "ACTIVE",
  "preferredLanguage": "EN",
  "employerVerificationStatus": null
}
```

Errors

Status	code	When
401	UNAUTHENTICATED	No token, an unknown token, or a token that was logged out
401	SESSION_EXPIRED	The token was idle for 10 minutes or passed its 12-hour expiry. Log in again.
403	ACCOUNT_DISABLED	The account was suspended or deleted after the token was issued.

`POST /api/auth/logout` — Bearer token

Ends the session for the token in the header. No body. Other sessions of the same user (other devices) stay active.

Response: 204 No Content (empty body). After this the token returns `401 UNAUTHENTICATED`.

Errors: the same 401 responses as `/me`.

`POST /api/auth/password/forgot` — No auth

AUTH-05, step 1. Sends a 6-digit reset code by SMS to the phone number of the account. The same OTP rules apply as for phone verification: valid 5 minutes, 30 seconds between sends, 3 resends per 30 minutes. Calling it again is the resend.

```
{ "identifier": "712345678" }      // phone in any accepted format, or the email
```

Response: 202 Accepted, identical whether or not an active account matches, so it cannot be used to discover accounts. Unverified and disabled accounts get no SMS.

```
{
  "message": "If an active account matches, a reset code has been sent by SMS ...",
  "otpExpiresInSeconds": 300,
  "resendAvailableInSeconds": 30
}
```

Errors: 400 `VALIDATION_FAILED` (missing identifier), 429 `OTP_RESEND_TOO_SOON` / `OTP_RESEND_LIMIT_REACHED` with `retryAfterSeconds`, 502 `SMS_DELIVERY_FAILED`.

`POST` `/api/auth/password/reset` — No auth

AUTH-05, step 2. Checks the code and sets the new password.

```
{
  "identifier": "712345678",
  "code": "483920",
  "newPassword": "N3w!Passw0rd",
  "confirmPassword": "N3w!Passw0rd"
}
```

Response: 204 No Content. Every session of the account is ended (all devices log in again), and a login lock from wrong passwords is lifted, since the user has proven they hold the phone. The new password follows the registration rules. No token is returned: the user logs in next.

Errors

Status	code	When
400	VALIDATION_FAILED	Weak password, `confirmPassword` mismatch, or the code is not 6 digits. `fieldErrors[0].field` names the field.
400	OTP_INVALID	Wrong code (`details.remainingAttempts`), or no active account matches
400	OTP_EXPIRED	The code is older than 5 minutes; request a new one
429	OTP_ATTEMPTS_EXCEEDED	5 wrong tries; request a new code

3. Public site endpoints

Read-only data for the landing page and the job board. No login, no request body.

Method	Path	Feeds
GET	`/api/public/jobs`	Job cards, keyword search, filters, pagination
GET	`/api/public/jobs/{id}`	A job's full details
GET	`/api/public/lookups`	Every filter dropdown, in one call
GET	`/api/public/employers/top`	The "Top employers" cards
GET	`/api/public/stats`	The headline numbers (jobs, employers, job seekers)
GET	`/api/public/cv-templates`	The CV template thumbnails

Which jobs are public? Only vacancies that are ACTIVE, before their application deadline, and posted by an APPROVED employer whose account is ACTIVE. Drafts, closed or expired jobs, and jobs from suspended employers never appear. The database view `v_open_vacancy` enforces this, so every public endpoint follows the same rule.

`GET /api/public/jobs` — No auth

Searches open jobs, **newest first**. All parameters are optional and combine with AND.

Parameter	Example	Meaning
`q`	`accountant`	Keyword, matched against the job title and the company name (ignores case)
`region`	`DAR_ES_SALAAM`	Region code, from `lookups.regions`
`type`	`FULL_TIME`	Employment type code, from `lookups.employmentTypes`
`category`	`FINANCE`	Industry/sector code, from `lookups.categories`
`experience`	`MID`	Required experience band, from `lookups.experienceLevels`
`salary`	`FROM_1M_TO_3M`	Monthly TZS salary band, from `lookups.salaryRanges`. Jobs whose advertised range overlaps the band match; jobs without a monthly TZS salary never match.
`posted`	`LAST_7_DAYS`	How recently the job was published, from `lookups.datePosted`
`page`	`1`	Page number, starting at 1. Default 1.
`size`	`10`	Jobs per page, 1 to 50. Default 10.

Codes ignore capitalisation. An unknown region, type or category code simply matches nothing; an unknown experience, salary or posted value is a 400.

Request

```
GET /api/public/jobs?region=DAR_ES_SALAAM&type=FULL_TIME&page=1&size=10
```

Response: 200 OK

```
{
  "items": [
    {
      "id": 1,
      "title": "Digital Marketing Specialist",
      "company": { "id": 41, "name": "CRDB Bank PLC", "initials": "CRDB" },
      "region": { "code": "DAR_ES_SALAAM", "nameEn": "Dar es Salaam",
                  "nameSw": "Dar es Salaam" },
      "employmentType": { "code": "FULL_TIME", "nameEn": "Full-time", "nameSw": "Muda Wote" },
      "category": { "code": "SALES_MARKETING", "nameEn": "Sales & Marketing",
                    "nameSw": "Mauzo na Masoko" },
      "salary": { "min": 1800000, "max": 2500000, "currency": "TZS", "period": "MONTH" },
      "publishedAt": "2026-10-28T08:12:40.120Z",
      "applicationDeadline": "2026-11-27T11:12:40.120Z"
    }
  ],
  "page": 1,
  "size": 10,
  "totalItems": 9,
  "totalPages": 1
}
```

- `category` is `null` when the employer did not choose one.

- `salary` is `null` when no salary is advertised. Either `min` or `max` may also be `null` (e.g. "from 4,000,000"). `period` is one of `HOUR`, `DAY`, `MONTH`, `YEAR`.
- Asking for a page past the end returns an empty `items` list with the real `totalItems`.

Errors

Status	code	When
400	VALIDATION_FAILED	Unknown `experience`/`salary`/`posted` value, `page` below 1, `size` outside 1-50, or a non-number. `fieldErrors[0].field` names the parameter.

GET /api/public/jobs/{id}

No auth

One open job with everything a job page needs.

Response: 200 OK: the job card fields plus:

```
{
  "id": 1,
  "title": "Digital Marketing Specialist",
  "company": { ... },  "region": { ... },  "employmentType": { ... },
  "category": { ... },  "salary": { ... },
  "publishedAt": "...",  "applicationDeadline": "...",
  "district": null,                      // district name, when given
  "locationDetails": null,               // free text, when given
  "description": "We are looking for ...",
  "requirements": "Strong communication skills; ...",
  "qualifications": "Relevant qualification in the field; ...",
  "workExperience": "At least 3 years of relevant experience",
  "minExperienceYears": 3,
  "minEducationLevel": { "code": "BACHELOR", "nameEn": "Bachelor's Degree",
                         "nameSw": "Shahada ya Kwanza" },
  "numberOfPositions": 1
}
```

Errors

Status	code	When
404	JOB_NOT_FOUND	No such job, or it is not public (draft, closed, expired, employer suspended)
400	VALIDATION_FAILED	The id is not a number

GET /api/public/lookups

No auth

Everything needed to fill the job filter form. Regions, employment types and categories come from the database (only active values, in display order); the three bands are fixed by the API.

Response: 200 OK

```
{
  "regions": [                                                    // 31, by name
    { "code": "ARUSHA", "nameEn": "Arusha", "nameSw": "Arusha" }, ...
  ],
  "employmentTypes": [                                            // 6
    { "code": "FULL_TIME", "nameEn": "Full-time", "nameSw": "Muda Wote" }, ...
  ],
  "categories": [                                                 // 18
    { "code": "ICT", "nameEn": "Information Technology", "nameSw": "TEHAMA" }, ...
  ],
  "experienceLevels": [ { "code": "ENTRY", "label": "Entry level (under 1 year)" }, ... ],
  "salaryRanges":     [ { "code": "UNDER_500K", "label": "Under TZS 500,000" }, ... ],
  "datePosted":       [ { "code": "LAST_24_HOURS", "label": "Last 24 hours" }, ... ]
}
```

Band	Codes
experienceLevels	`ENTRY` (under 1 year), `JUNIOR` (1-3), `MID` (3-5), `SENIOR` (5+)
salaryRanges	`UNDER_500K`, `FROM_500K_TO_1M`, `FROM_1M_TO_3M`, `OVER_3M` (monthly, TZS)
datePosted	`LAST_24_HOURS`, `LAST_7_DAYS`, `LAST_30_DAYS`

Pass a band's `code` to `/api/public/jobs` as `experience`, `salary` or `posted`.

`GET /api/public/employers/top` — No auth

Approved employers ranked by how many jobs they have open right now (ties by name). Employers with no open jobs are left out.

Parameter	Example	Meaning
`limit`	5	How many employers, 1 to 20. Default 5.

Response: 200 OK

```
[
  {
    "id": 46,
    "name": "Halotel",
    "initials": "H",
    "industry": { "code": "TELECOM", "nameEn": "Telecommunications", "nameSw": "Mawasiliano ya Simu" },
    "openJobs": 4
  }
]
```

`industry` is `null` when the employer has not chosen one. **Errors:** 400 `VALIDATION_FAILED` when `limit` is outside 1-20.

GET /api/public/stats — No auth

Live headline numbers, counted at the moment of the request.

Response: 200 OK

```
{
  "openJobs": 22,              // public jobs right now (same rule as /api/public/jobs)
  "employers": 8,              // approved employers with an active account
  "jobSeekers": 1,             // verified (ACTIVE) job seeker accounts
  "jobsPostedLast30Days": 20   // jobs published in the last 30 days, open or closed since
}
```

Figures such as "24/7 support" or "98% satisfaction" have no data source and stay as text in the UI.

GET /api/public/cv-templates — No auth

The active CV templates, in display order.

Response: 200 OK

```
[
  {
    "id": 1,
    "code": "CLASSIC",
    "nameEn": "Classic",
    "nameSw": "Kawaida",
    "descriptionEn": "Traditional single-column layout",
    "descriptionSw": "Mpangilio wa kawaida wa safu moja",
    "scheme": "light",        // thumbnail background: "light" | "dark"
    "accent": "#14213D"       // thumbnail accent colour
  }
]
```

code	name	scheme	accent
CLASSIC	Classic	light	#14213D
MODERN	Modern	light	#2FB573
PROFESSIONAL	Professional	dark	#FD5C20
MINIMAL	Minimal	light	#2F8FF5
GRADUATE	Graduate	light	#B064F7

4. Account settings endpoints

The signed-in user's own account, behind the job seeker **Settings** screen. Every route needs `Authorization: Bearer <token>`. The `/api/me/settings` routes are for job seeker accounts; other roles get 403 `JOB_SEEKERS_ONLY`. Each PUT returns the full, updated settings.

Method	Path	Purpose
GET	`/api/me/settings`	Everything the Settings screen shows
PUT	`/api/me/settings/notifications`	Save notification choices
PUT	`/api/me/settings/privacy`	Save what employers may see
PUT	`/api/me/settings/language`	Save the preferred language
POST	`/api/me/password`	Change the password (AUTH-05)
GET	`/api/me/saved-jobs/ids`	Ids of the jobs the user bookmarked
PUT	`/api/me/saved-jobs/{id}`	Bookmark a job
DELETE	`/api/me/saved-jobs/{id}`	Remove a bookmark

`GET /api/me/settings` — Bearer token

Response: 200 OK

```
{
  "account": {
    "fullName": "Radiant Juma",
    "email": "radiant@avi.co.tz",
    "phone": "+255625689904",
    "dateOfBirth": "2001-01-12",          // null until the profile editor sets it
    "gender": "MALE",                     // see below; null until set
    "location": {
      "region": { "code": "DAR_ES_SALAAM", "nameEn": "Dar es Salaam",
                  "nameSw": "Dar es Salaam" },          // or null
      "district": null,
      "address": "Mikocheni"
    },
    "about": "Marketing professional ..."                // or null
  },
  "notifications": { "email": true, "applicationUpdates": true,
                     "jobAlerts": true, "newsletter": false },
  "privacy": { "profileVisible": true, "showEmail": false, "showPhone": false },
  "preferences": { "language": "EN" }                   // EN | SW
}
```

`gender` is one of `MALE`, `FEMALE`, `OTHER`, `PREFER_NOT_TO_SAY`. The notification and privacy values shown are the defaults for a new job seeker. The account part is read-only here.

PUT /api/me/settings/notifications — Bearer token

All four fields are required booleans; a missing field is a 400, never a silent `false`.

```
{ "email": true, "applicationUpdates": true, "jobAlerts": false, "newsletter": false }
```

`jobAlerts` is the same setting the job-alert matching uses (`receive_job_alerts`). **Response: 200 OK** with the full settings.

PUT /api/me/settings/privacy — Bearer token

```
{ "profileVisible": true, "showEmail": false, "showPhone": true }
```

All three fields are required booleans. **Response: 200 OK** with the full settings.

PUT /api/me/settings/language — Bearer token

```
{ "language": "SW" }
```

`EN` (English) or `SW` (Kiswahili), any capitalisation. It is stored on the account, so `/api/auth/me` reports it as `preferredLanguage`. **Response: 200 OK** with the full settings; 400 `VALIDATION_FAILED` for any other value.

POST /api/me/password — Bearer token

```
{
  "currentPassword": "Str0ng!Pass",
  "newPassword": "N3w!Passw0rd",
  "confirmPassword": "N3w!Passw0rd"
}
```

The new password follows the registration rules (8-64 characters with an uppercase letter, a lowercase letter, a digit and a special character) and must differ from the current one.

Response: 204 No Content. The session that made the change stays signed in; **every other session of the user is ended** (other devices must log in again with the new password).

Errors

Status	code	When
400	VALIDATION_FAILED	`confirmPassword` does not match, the new password is too weak, or it equals the current one. `fieldErrors[0].field` names the field.
400	CURRENT_PASSWORD_INCORRECT	The current password is wrong (field `currentPassword`). It is a 400, not a 401, so the user stays signed in. The attempt is audited.
401	UNAUTHENTICATED / SESSION_EXPIRED	No valid session

GET `/api/me/saved-jobs/ids` — Bearer token

The ids of the jobs the job seeker bookmarked, newest first: enough to fill in the bookmark icons on a job list. Job seeker accounts only (403 `JOB_SEEKERS_ONLY` otherwise).

```
{ "vacancyIds": [15, 1, 7] }
```

PUT `/api/me/saved-jobs/{id}` — Bearer token

Bookmarks the job. Idempotent: saving a saved job is fine. Only public (open) jobs can be saved. **Response: 204. Errors:** 404 `JOB_NOT_FOUND` (no such open job), 403 `JOB_SEEKERS_ONLY`.

DELETE `/api/me/saved-jobs/{id}` — Bearer token

Removes the bookmark. Idempotent. **Response: 204.**

5. Limits

These values are read from the database (`system_setting` table), so they can change without a code release. The endpoints report the live values in `otpExpiresInSeconds`, `resendAvailableInSeconds` and `idleTimeoutSeconds`.

Limit	Current value	Setting
OTP validity	5 minutes	`OTP_TTL_SECONDS`
Wrong OTP tries per code	5	application config
Wait between resends	30 seconds	application config
Resends per window	3 in 30 minutes	`OTP_MAX_RESENDS`, `OTP_RESEND_WINDOW_MINUTES`
Minimum password length	8	`PASSWORD_MIN_LENGTH`
Wrong passwords before lock	5	`LOGIN_MAX_FAILED_ATTEMPTS`
Lock duration	15 minutes	`LOGIN_LOCK_MINUTES`
Session idle timeout	10 minutes	`SESSION_IDLE_TIMEOUT_MINUTES`
Session absolute lifetime	12 hours	application config

6. All error codes

Status	code	Endpoints
400	VALIDATION_FAILED	all endpoints with a body; public endpoints with a bad query or path parameter
400	MALFORMED_REQUEST	all endpoints with a body
400	OTP_INVALID	otp/verify, password/reset
400	OTP_EXPIRED	otp/verify, password/reset
400	CURRENT_PASSWORD_INCORRECT	me/password

Status	code	Endpoints
401	INVALID_CREDENTIALS	login
401	UNAUTHENTICATED	me, logout
401	SESSION_EXPIRED	me, logout
403	PHONE_NOT_VERIFIED	login
403	ACCOUNT_DISABLED	login, me, logout and every /api/me route
403	JOB_SEEKERS_ONLY	me/settings and me/saved-jobs routes, for employer or admin accounts
404	NOT_FOUND	any unknown path
404	JOB_NOT_FOUND	public/jobs/{id}, PUT me/saved-jobs/{id}
405	METHOD_NOT_ALLOWED	wrong HTTP method on a known path
409	PHONE_ALREADY_REGISTERED	register
409	PHONE_PENDING_VERIFICATION	register
409	EMAIL_ALREADY_REGISTERED	register
409	CONFLICT	register (two identical registrations at the same moment)
415	UNSUPPORTED_MEDIA_TYPE	all endpoints with a body, when it is not sent as JSON
423	ACCOUNT_LOCKED	login
429	OTP_ATTEMPTS_EXCEEDED	otp/verify, password/reset
429	OTP_RESEND_TOO_SOON	otp/resend, password/forgot
429	OTP_RESEND_LIMIT_REACHED	otp/resend, password/forgot
500	INTERNAL_ERROR	any (unexpected server error)
502	SMS_DELIVERY_FAILED	register, otp/resend, password/forgot

7. Notes for the current version

- **Settings need migration 05.** `db/oracle/05_settings.sql` adds date of birth, gender and the notification and privacy columns to `job_seeker_profile`. It is additive and safe to re-run; it has been applied to the shared development database.
- **Not saved by the API:** Appearance (light/dark/system) is a per-device choice kept in the browser, and Region is fixed to Tanzania. Date of birth, gender, location and "about" are shown on Settings but are edited by the profile editor, which has no API yet.
- **Demo data.** Employers cannot be approved through the app yet, so the shared development database holds demo data from `db/oracle/04_seed_demo.sql`: 8 approved employers and 22 open jobs (demo accounts use `demo+...@halokazi.test` emails and cannot log in). `98_hide_demo.sql` takes it off the public endpoints. Never load it into production.
- **No logos yet.** Companies come with `initials` for a badge; logos arrive when file storage is built. Brand colours are not stored, so the UI chooses them.
- **CV templates:** the requirements (CV-02) define 5 templates, so the API returns 5. The CV builder screens still use their own template list, which does not match these codes yet.

- **No real SMS yet.** OTP codes are written to the backend's log as `[DEV SMS] to +255... : Your Halokazi verification code is 123456 ...`. A real SMS gateway will replace this without any change to the API.
- **Not built yet:** account deletion (AUTH-11), employer verification documents, per-IP rate limiting (AUTH-13), and APIs for the profile, applications, CVs and job alerts screens.
- **Login accepts phone or email** (AUTH-04) in one `identifier` field, on the login and forgot-password screens alike.